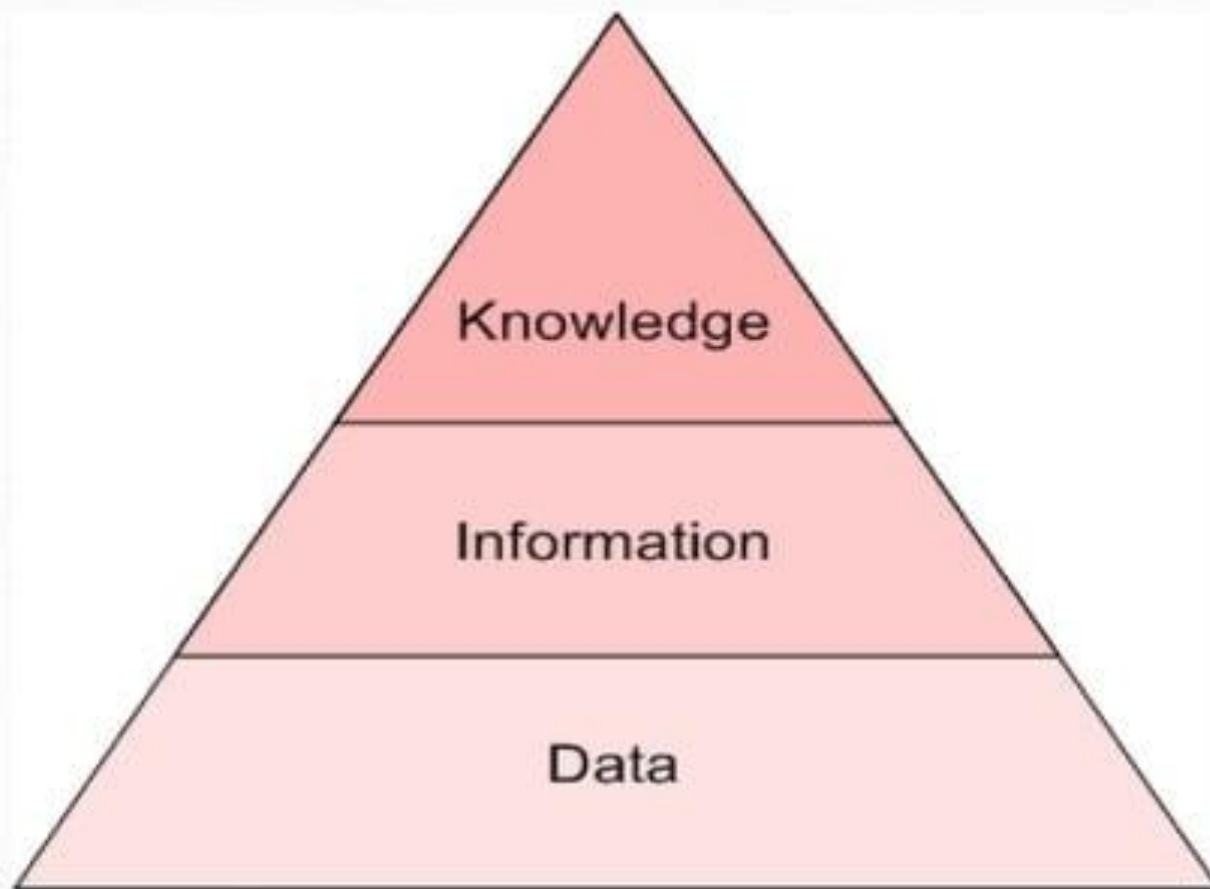




Information Security



Data vs. Information vs. Knowledge

- **Data**- raw numbers, words, etc. that lack context or meaning (e.g., 1.4%)
- **Information**- application of structure to data to convey meaning (e.g., “unemployment is down 1.4% in the past 6 months)
- **Knowledge**- understanding of a specific subject through experience or education (e.g., “a 1.4% decrease typically indicates sustainable growth)



Figure Data, Information, and Knowledge as a Process

$\text{Data} + \text{context} = \text{Information}$
 $\text{Information} + \text{Rules} = \text{Knowledge}$

Information

- Information is a form of knowledge that we acquire through education, communication, Practical experience , Research and Analysis.
- It consists of Data, Facts and conclusions.

Information can be

- Created
- Modified
- Stored
- Destroyed
- Processed
- Used (for proper and improper purposes)
- Transmitted
- Corrupted
- Lost
- stolen

Information can be

- Printed or written on paper
- Stored electronically
- Transmitted by post or using electronic means
- Shown on corporate videos
- Displayed and published on the web
- Verbal or spoken in conversations

Information Security

- **Information security**, sometimes shortened to **InfoSec**, is the practice of preventing unauthorized access, use, disclosure, disruption, modification, inspection, recording or destruction of information
- **Information security** in today's enterprise is "well informed sense of assurance that the information risks and control are in balance
- **Security** is a non functional requirement assumes that the system is correctly implemented according to functional requirement.
- Security **is a process** not a product

Various Securities

- Data security
 - **Data security** is the means of ensuring that data is kept safe from corruption and that access to it is suitably controlled.
- Computer Security
 - The objective of computer security includes protection of information and property from theft, corruption, or natural disaster, Malware: malicious software
 - includes computer viruses, worms, Trojan horses,,

Network Security

- protect the network and the network-accessible resources from unauthorized access, consistent and continuous monitoring and measurement of its effectiveness

The Need for Computer Security

- Why the need for Computer Security?
 - The value of computer assets and services
- What is the new IT environment?
 - Networks and distributed applications/services
 - Electronic Commerce (E-commerce, E-business)

Why need security?

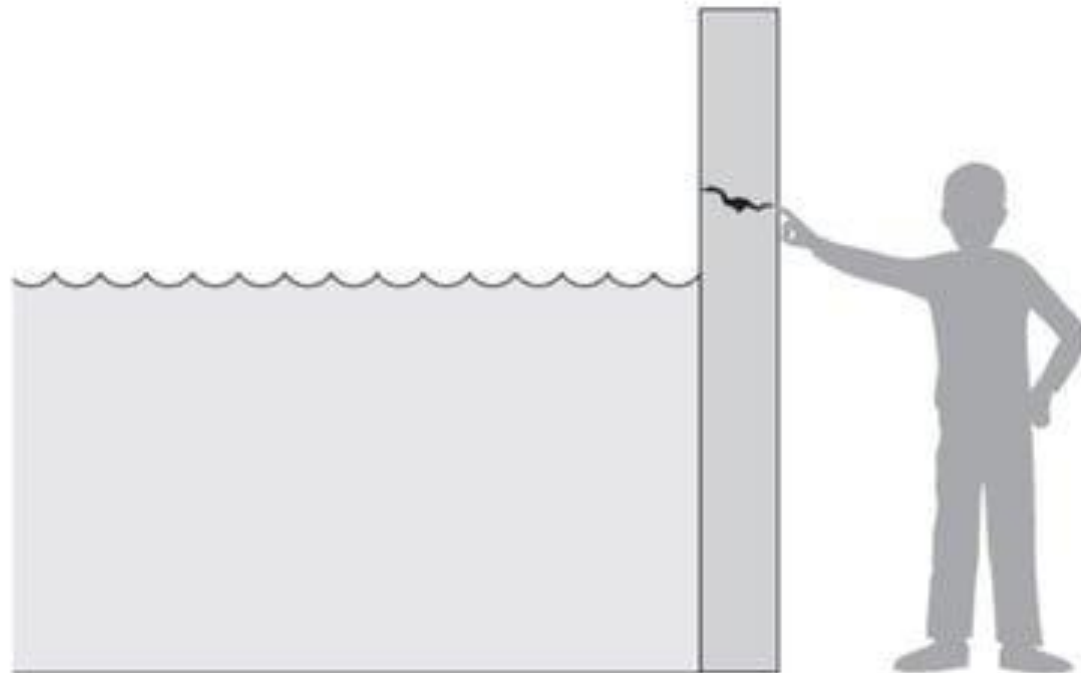
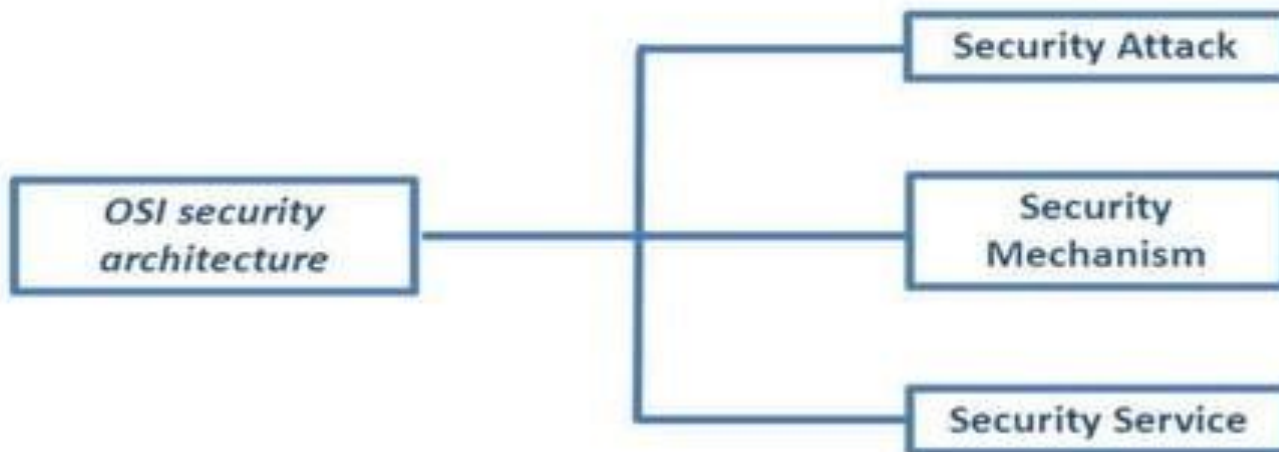


FIGURE 1-1 Threats, Controls, and Vulnerabilities.

Vulnerability threat and attack

- **Vulnerabilities** : i) **Weakness** in a security system.
ii) "Vulnerability" refers to the **security flaws** in a system that allow an attack to be successful.
crack in wall or wall is short in height.
- **Threats** : i) **Set of circumstances** that might exploit vulnerability
ii) "threat" refers to the **source and means** of a particular type of attack
Overflow of water, wall may be break
- **Attacks** : i) When weakness is **exploited**
Actually breaking of wall.

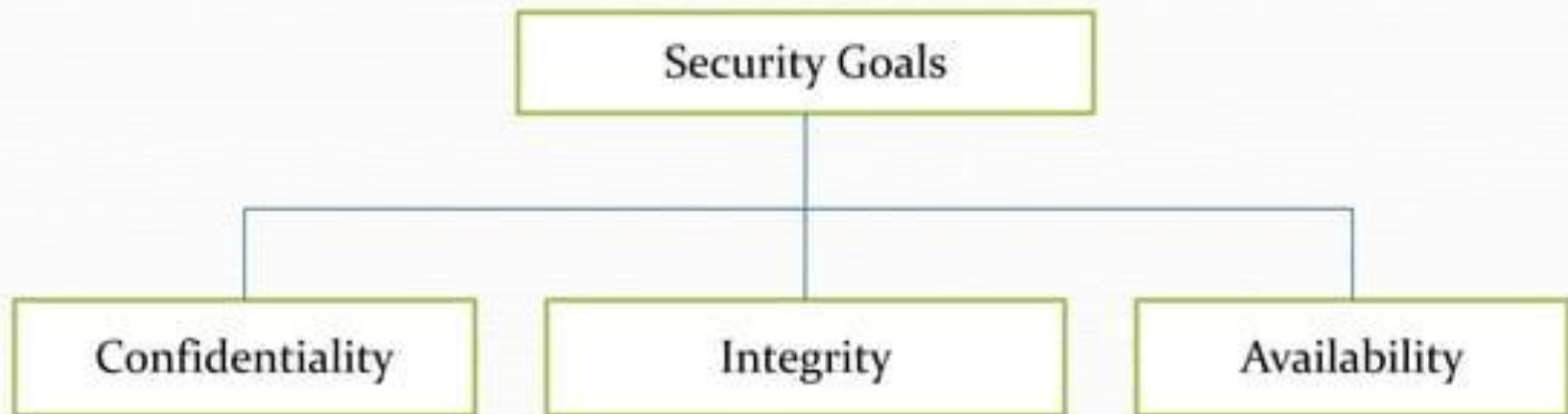
OSI security architecture



KEY POINTS

- ❖ The **Open Systems Interconnection** (OSI) security architecture provides a systematic framework for defining security attacks, mechanisms, and services.
- ❖ **Security attacks** are classified as either passive attacks, which include unauthorized reading of a message or file and traffic analysis or active attacks, such as modification of messages or files, and denial of service.
- ❖ A **security mechanism** is any process (or a device incorporating such a process) that is designed to detect, prevent, or recover from a security attack. Examples of mechanisms are encryption algorithms, digital signatures, and authentication protocols.
- ❖ **Security services** include authentication, access control, data confidentiality, data integrity, nonrepudiation, and availability.

Security Goals.



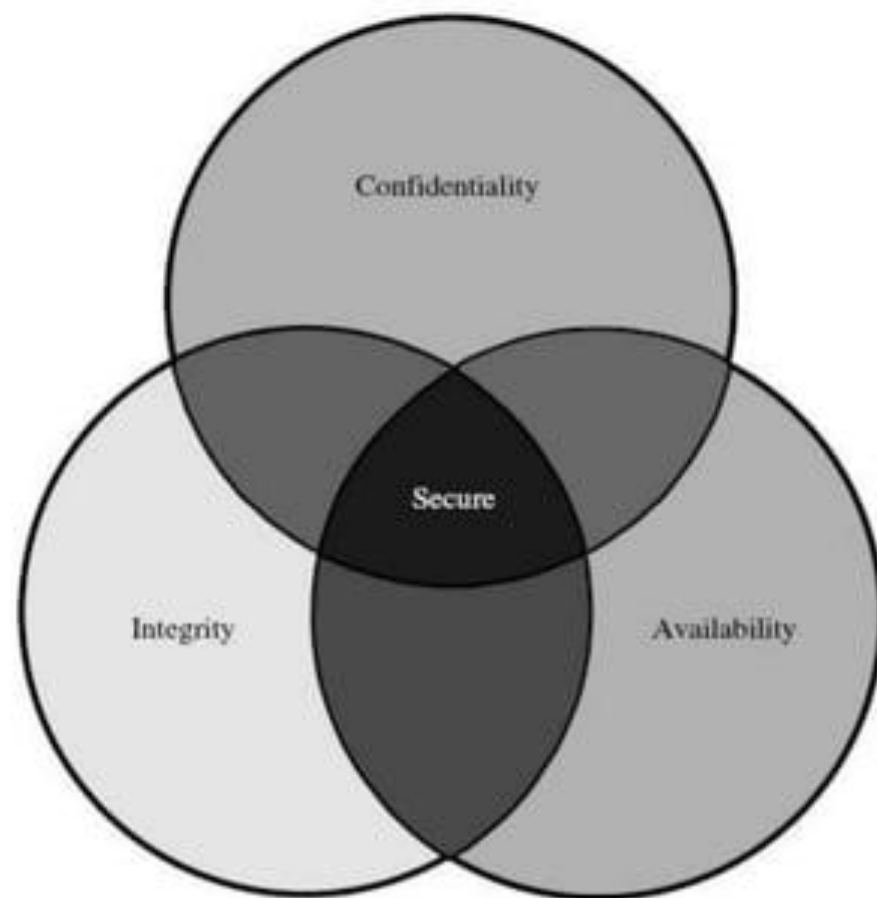


FIGURE 1-3 Relationship Between Confidentiality, Integrity, and Availability.

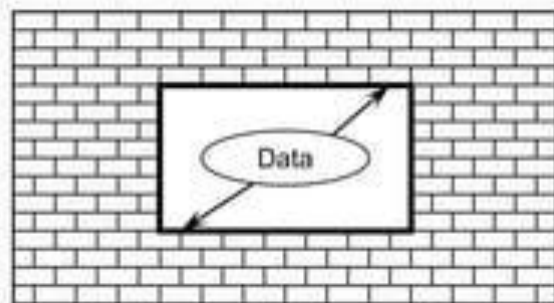
Threats, Vulnerabilities, and Controls

A **vulnerability** is a weakness in the security system, for example, in procedures, design, or implementation, that might be exploited to cause loss or harm.

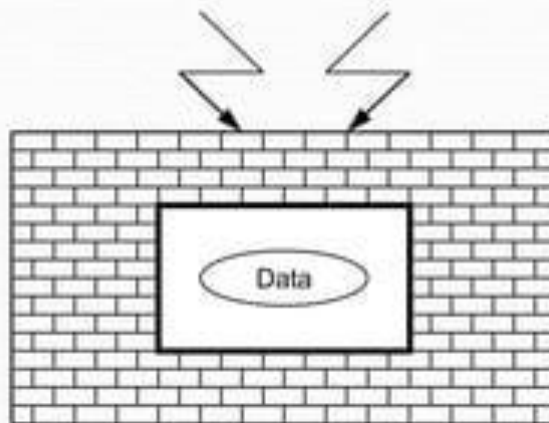
A **threat** to a computing system is a set of circumstances that has the potential to cause loss or harm.

A threat is blocked by control of a vulnerability.

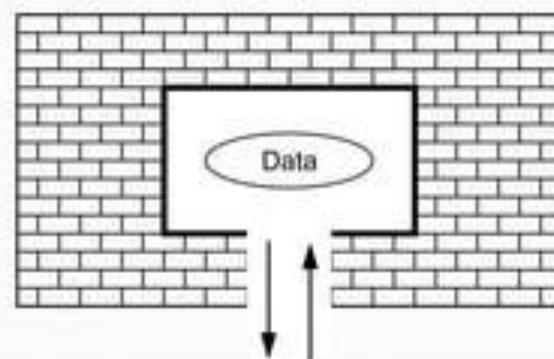
Security of Data



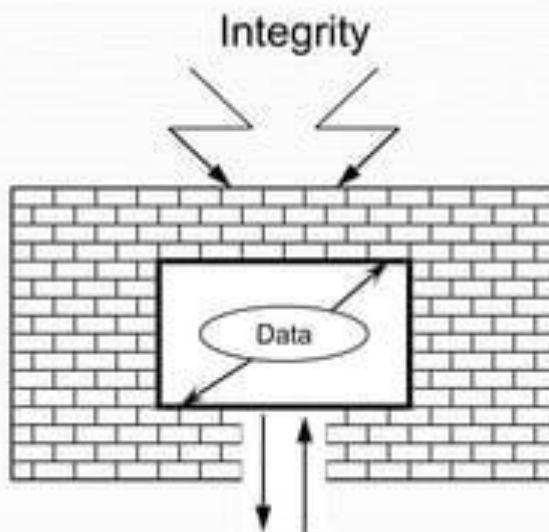
Confidentiality



Integrity



Availability



Secure Data



"Ensures that only authorized users
(confidentiality) have access to accurate and
complete information (integrity) when
required (availability)

Attacks

The three goals of security—confidentiality, integrity and availability—can be threatened by security attacks. Figure 16.2 relates the taxonomy of attack types to security goals.

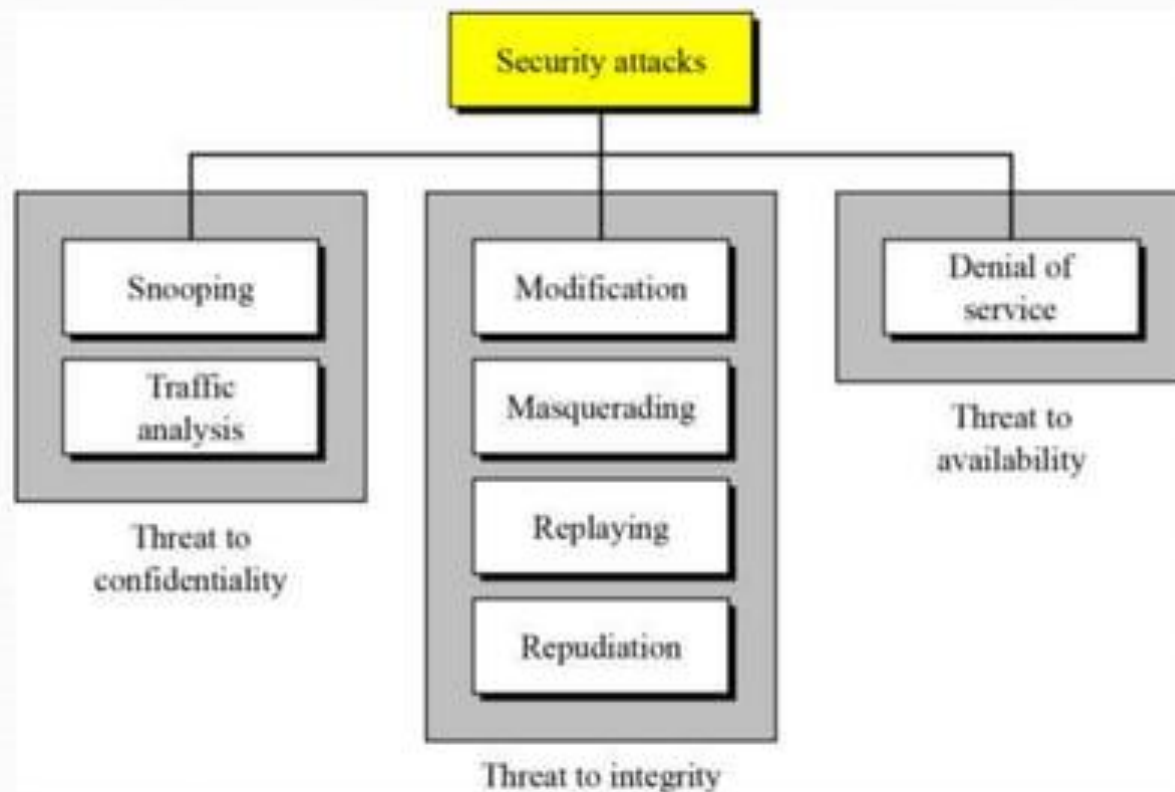


Figure 16.2 Taxonomy of attacks with relation to security goals

Computer Security Requirements

- Confidentiality(Secrecy)
- Integrity
- Availability
- Authenticity
- Non-repudiation

Secrecy (Confidentiality)

- Secrecy requires that the information in a computer system only be accessible for reading by authorized parties.
- This type of access includes:
 - Printing
 - Displaying
 - Other forms of disclosure,

Integrity

- Integrity requires that the computer system asset can be modified only by authorized parties.
- Modification includes:
 - Writing
 - Changing
 - Changing status
 - Deleting and
 - Creating

Availability

- Availability requires that computer system assets are available to authorized parties.
- Availability is a requirement intended to assure that systems work promptly and service is not denied to authorized users.

Authenticity

- Authenticity means that parties in a information services can ascertain the identity of parties trying to access information services.
- Also means that the origin of the message is certain.
- Receiver should be ensure about sender's identity, that false sender(imposter) should has not sent the message

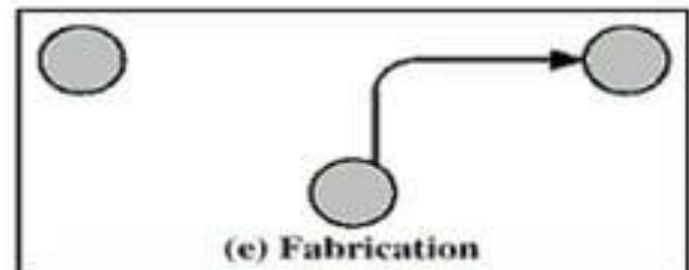
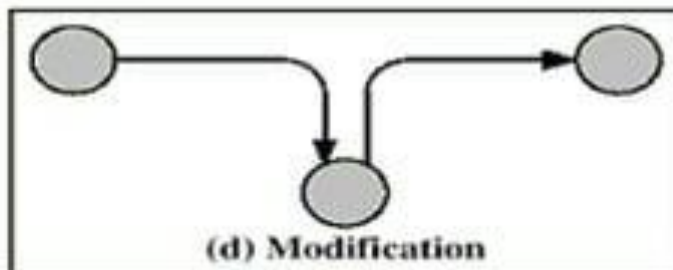
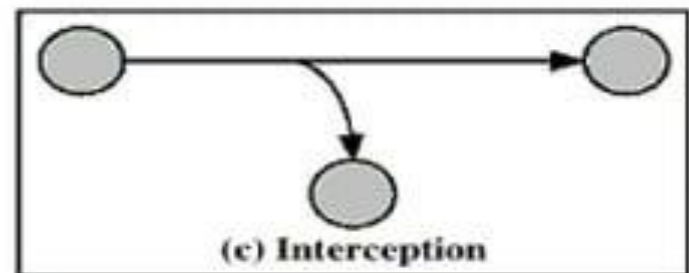
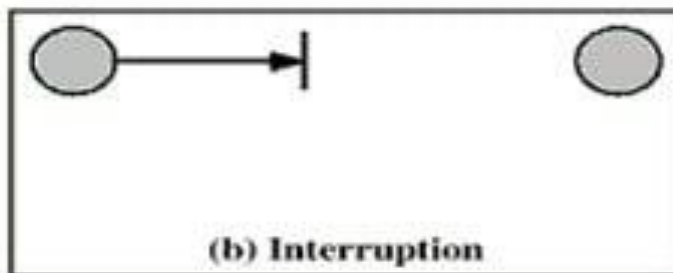
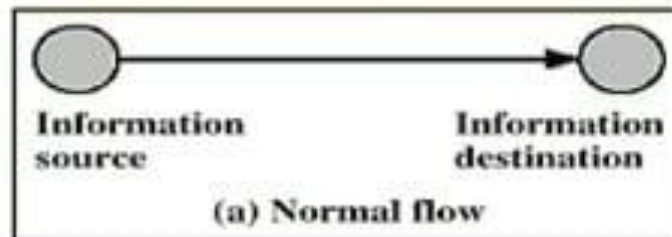
Non-repudiation

- Originator of communications can't deny it later.
- Without non-repudiation you could place an order for 1 million dollars of equipment online and then simply deny it later.
- Or you could send an email inviting a friend to the dinner and then disclaim it later.
- Non-repudiation associates the identity of the originator with the transaction in a non-deniable way.

Type of Attacks/Threats in Computer Systems

- A *threat* is a danger which could affect the security (confidentiality, integrity, availability) of assets, leading to a potential loss or damage.
- ❖ **Hacker** using computer is a **subject of an attack** **remote system** that is the **object of an attack**
- Interruption
- Interception
- Modification
- Fabrication

Security attacks



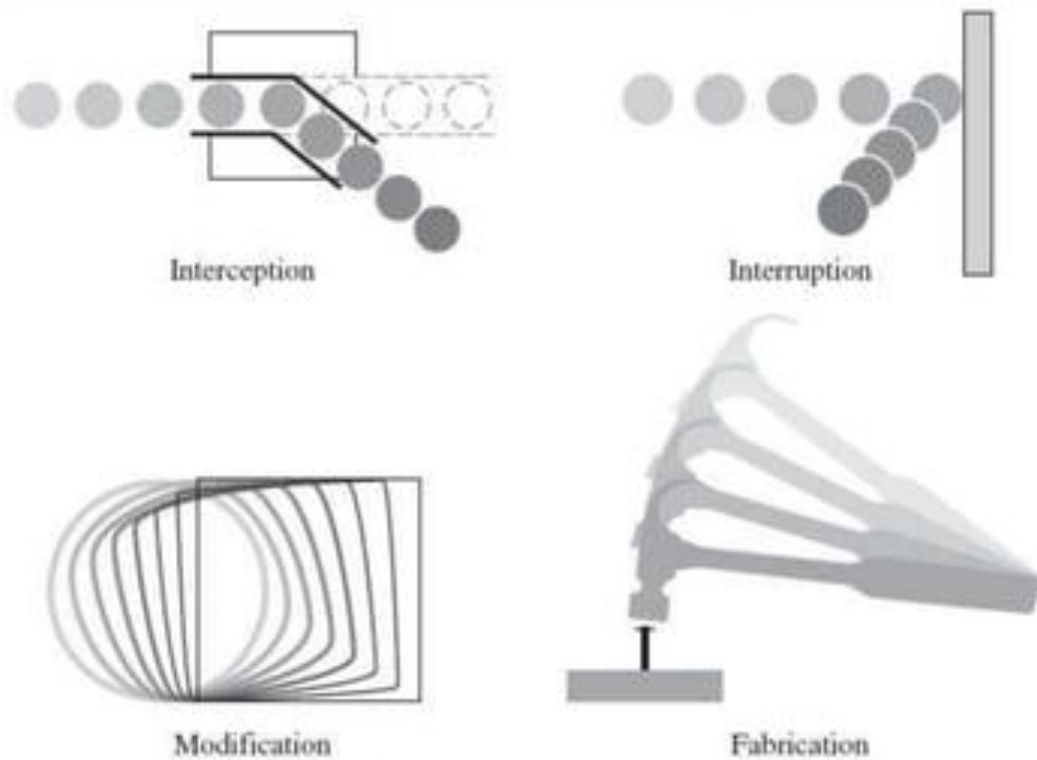
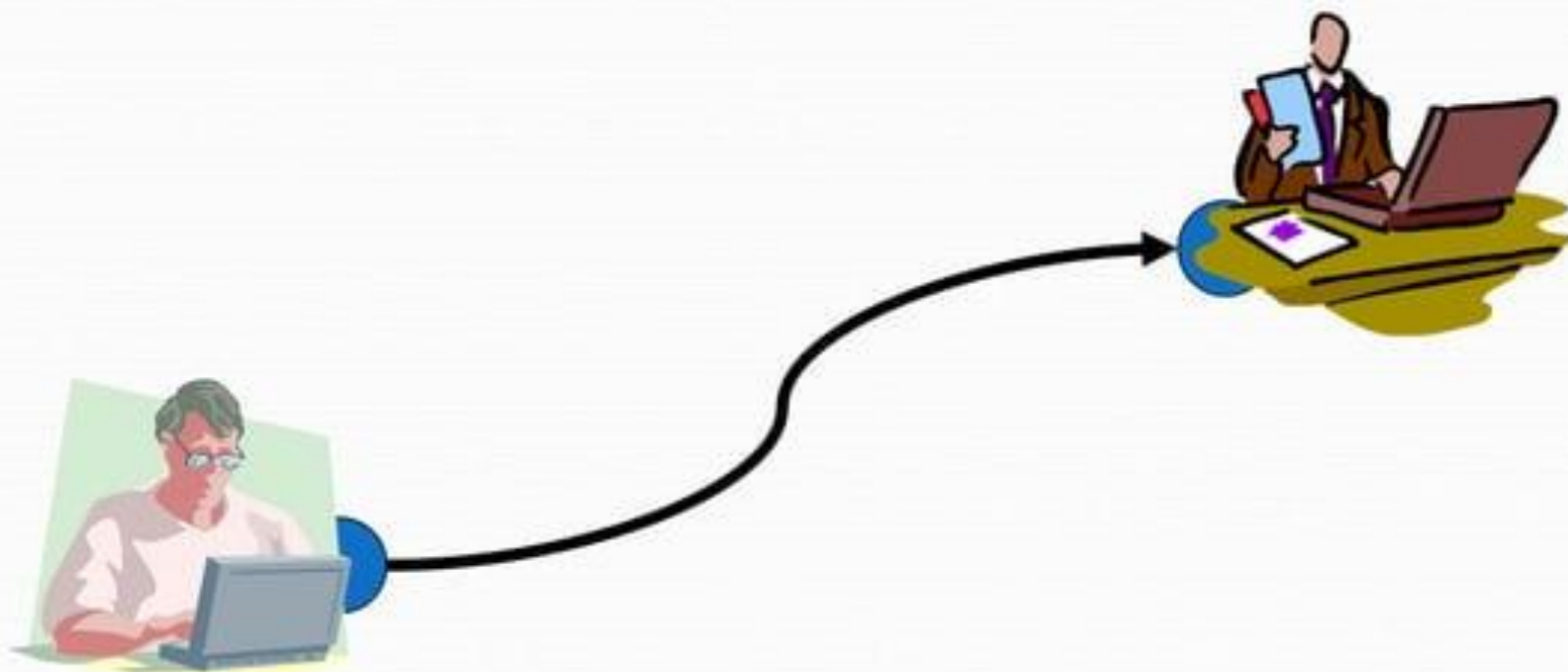


FIGURE 1-2 System Security Threats.

Types of Threats

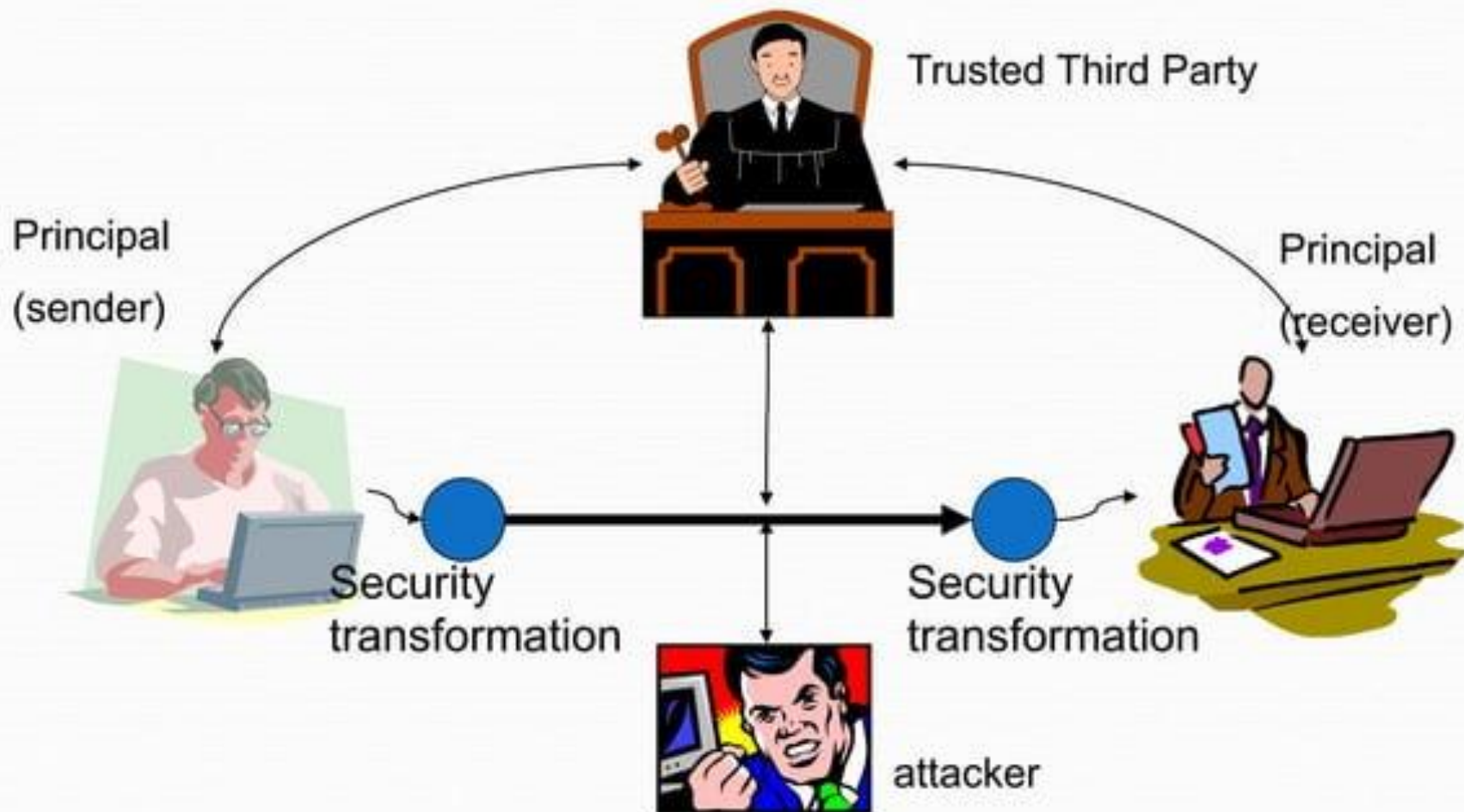
- An **interception** means that some unauthorized party has gained access to an asset.
- In an **interruption**, an asset of the system becomes lost, unavailable, or unusable.
- If an unauthorized party not only accesses but tampers with an asset, the threat is a **modification**.
- Finally, an unauthorized party might create a **fabrication** of counterfeit objects on a computing system.

Information Transferring

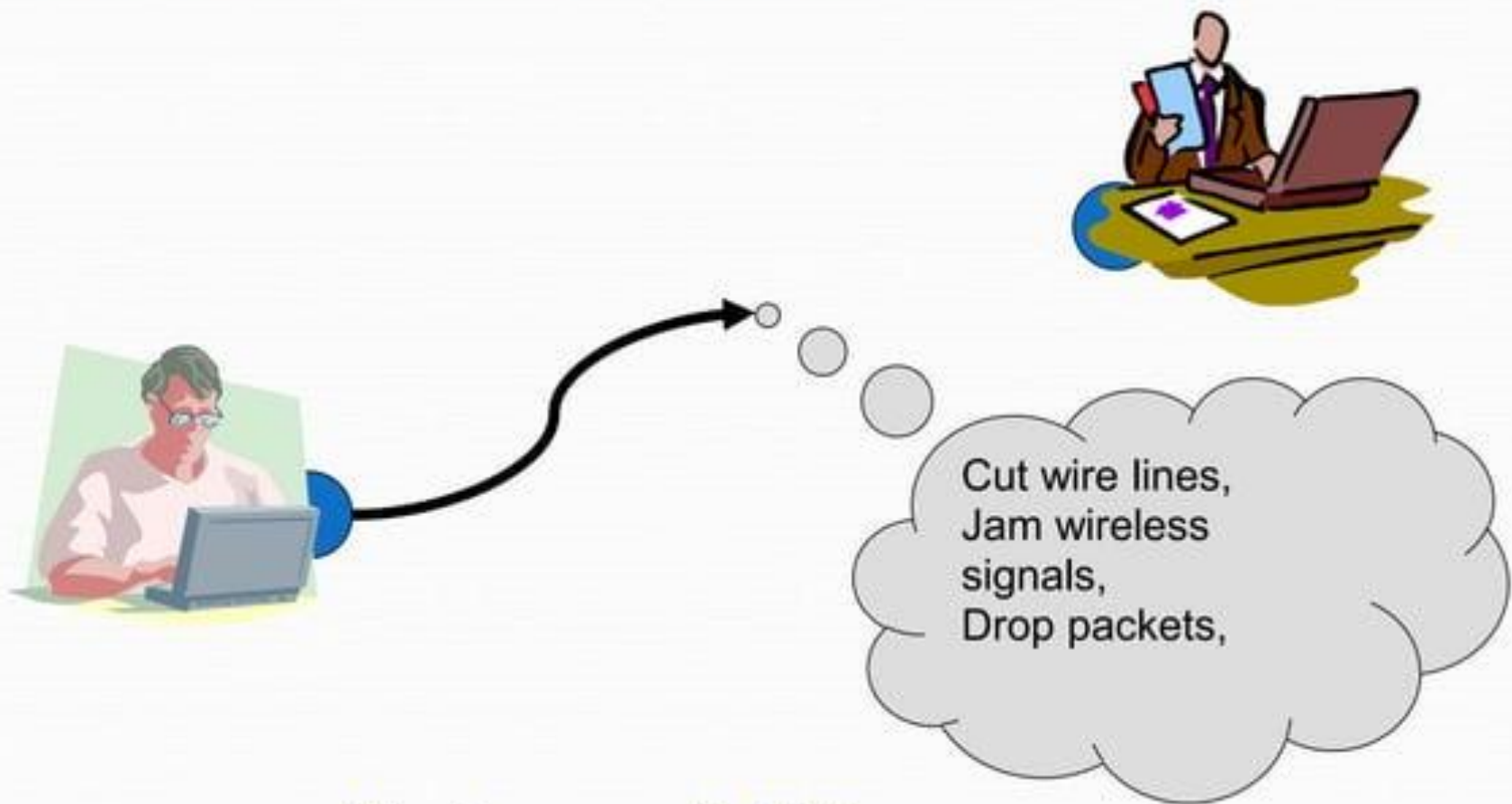


Normal Flow

Network Security Model



Attack: Interruption

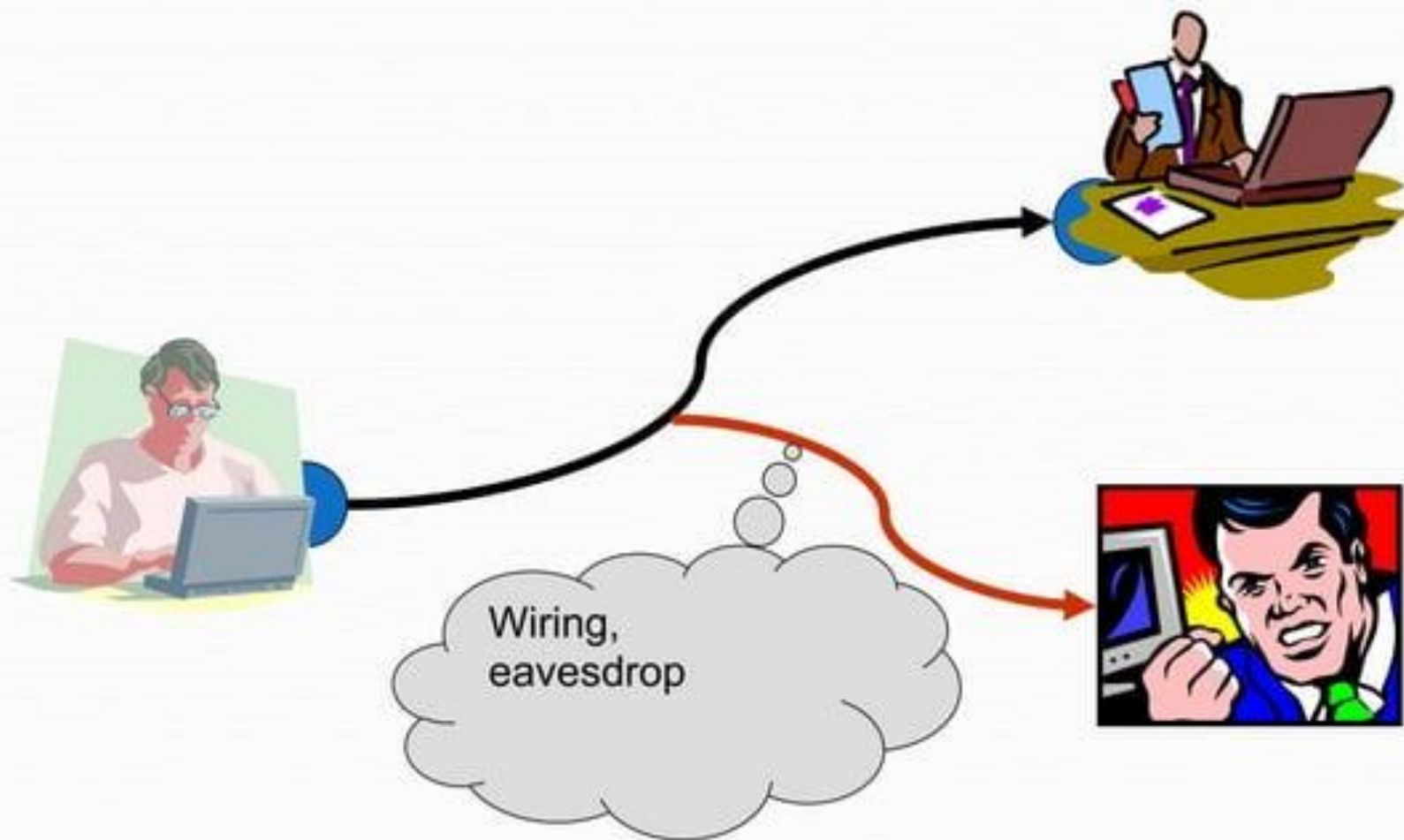


- Attack on **availability**

Attack: Interruption

- An asset of the system is destroyed or becomes unavailable or unusable. This is an attack on the **availability**.
- Examples include destruction of a piece of hardware, such as a hard disk, the cutting of a communication link, or the disabling of the file management system.
- **DOS** - Denial of Service Attacks have become very well known.

Attack: Interception

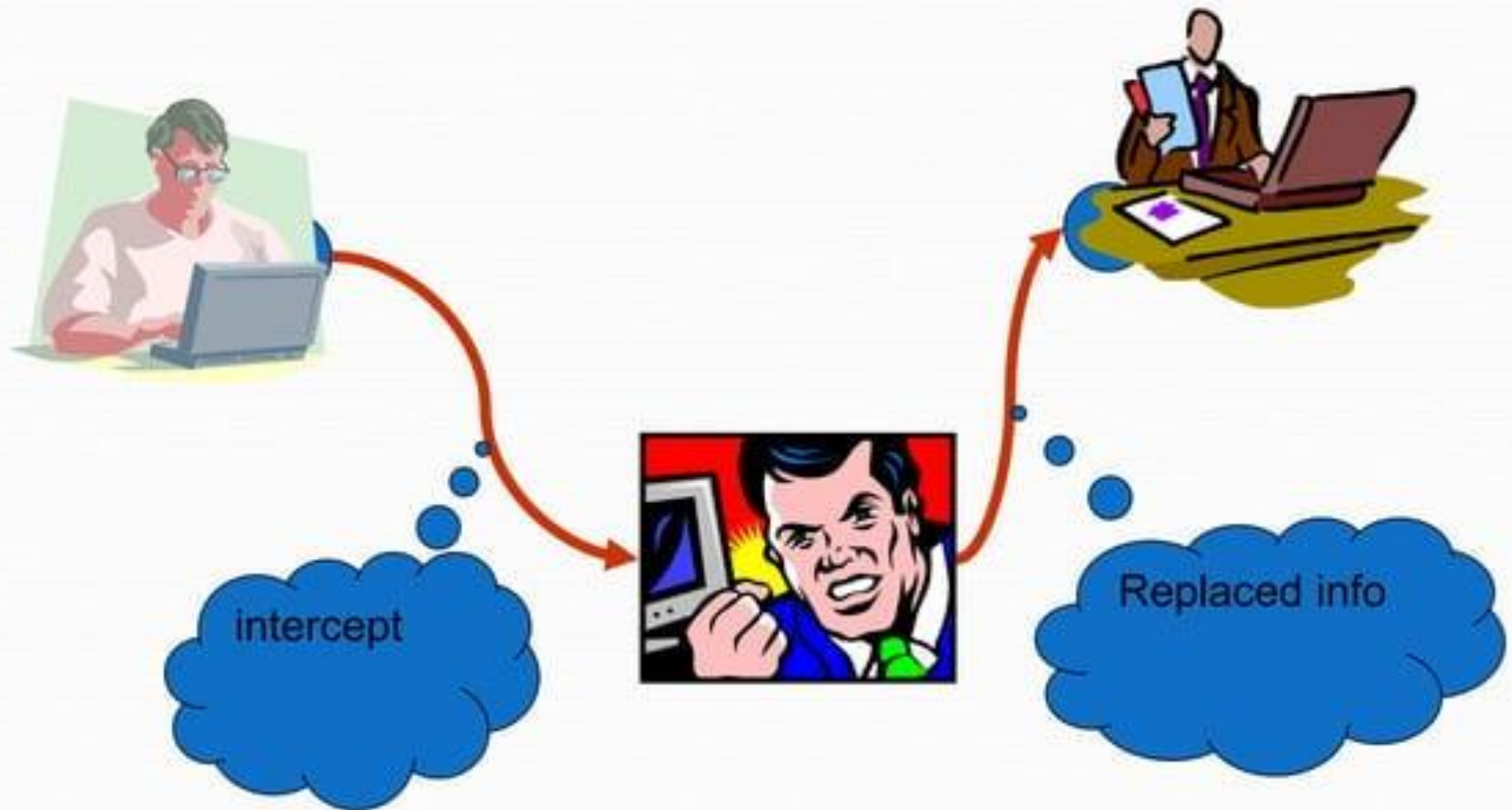


- **Attack on confidentiality**

Attack: Interception

- Information disclosure/information leakage
- An unauthorized party gains access to an asset.
- This is an attack on confidentiality.
- The unauthorized party could be a person, a program, or a computer.
- Examples include:
 - wiretapping to capture data in a network
 - the illicit copying of files or programs

Attack: Modification

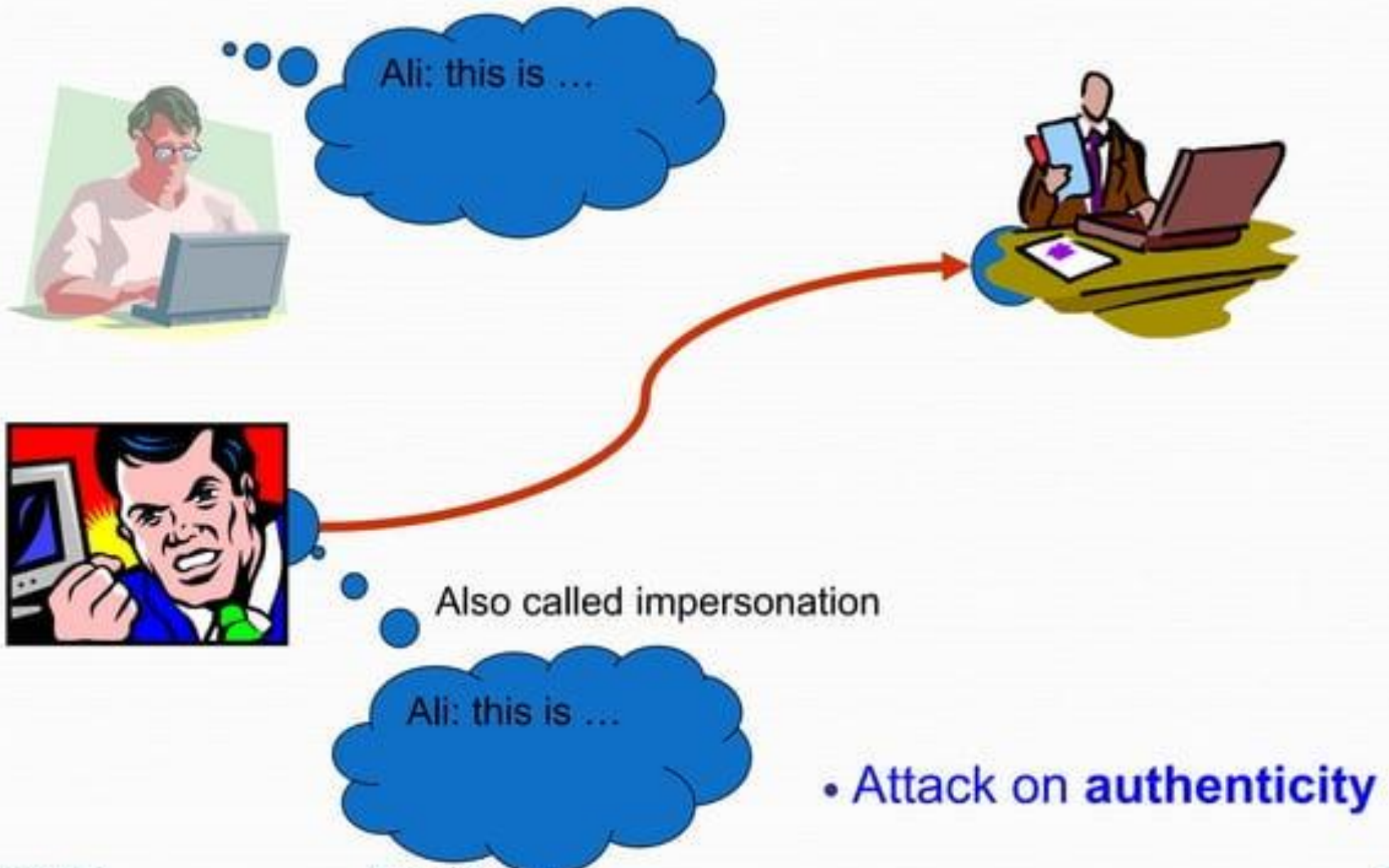


- Attack on **integrity**

Attack: Modification

- Modification is integrity violation.
- An unauthorized party not only gains access to but tampers with an asset.
- This is an attack on the integrity.
- Examples include changing values in a data file, altering a program so that it performs differently, and modifying the content of a message being transmitted in a network.

Attack: Fabrication



Attack: Fabrication

- An unauthorized party inserts counterfeit objects into the system. This is an attack on the authenticity.

Classification of Attacks

- Computer Security attacks can be classified into two broad categories:
 - **Passive Attacks** can only observe communications or data.
 - **Active Attacks** can actively modify communications or data. Often difficult to perform, but very powerful. Examples include
 - Mail forgery/modification

Passive and active attacks

- **Passive attacks**

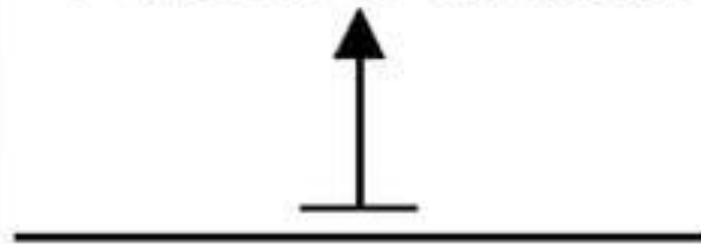
- No modification of content or fabrication
- Eavesdropping to learn contents or other information (transfer patterns, traffic flows etc.)

- **Active attacks**

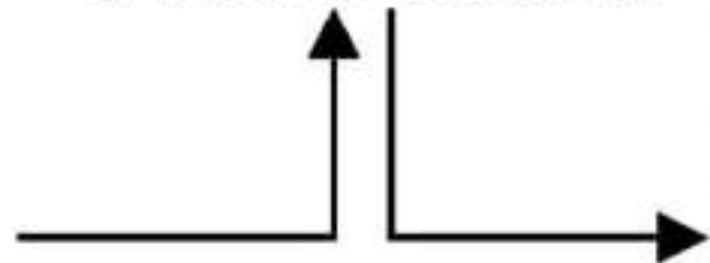
- Modification of content and/or participation in communication to
 - Impersonate legitimate parties
 - Modify the content in transit
 - Launch denial of service attacks

Passive Attacks and Active Attacks

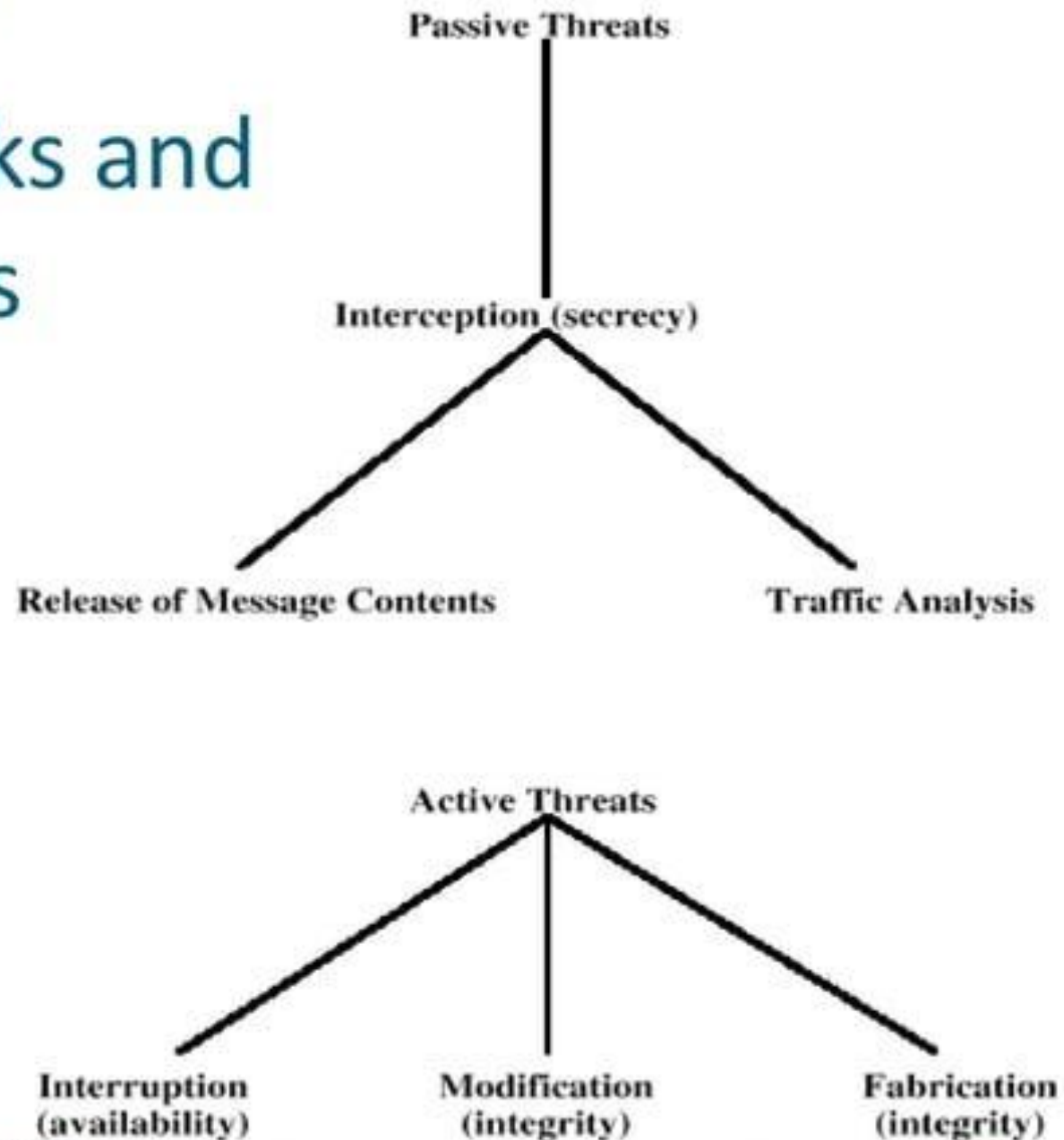
Passive attack



Active attack



Passive Attacks and Active Attacks



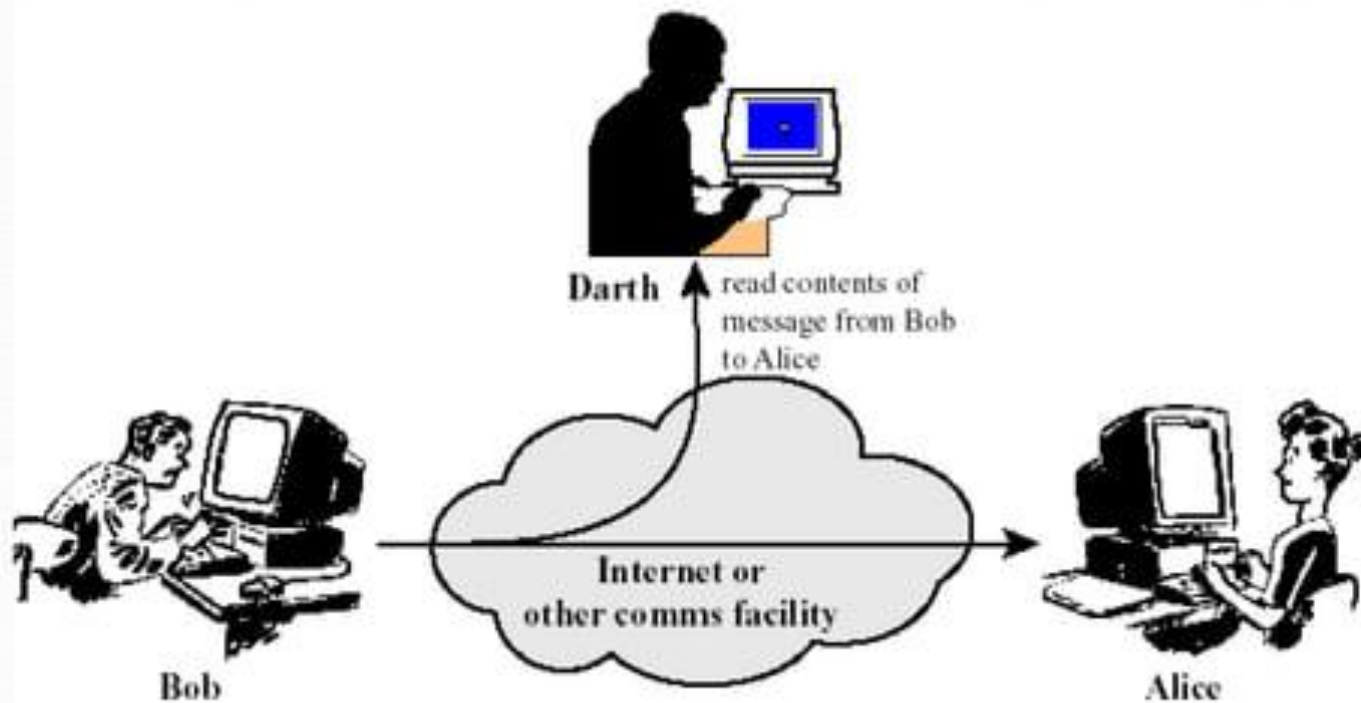
Passive Attacks

- Eavesdropping on or monitoring of transmission.
- The goal of the opponent is to obtain information that is being transmitted.
- Two types:
 - Release-of-message contents
 - Traffic Analysis

Release-of-message Contents

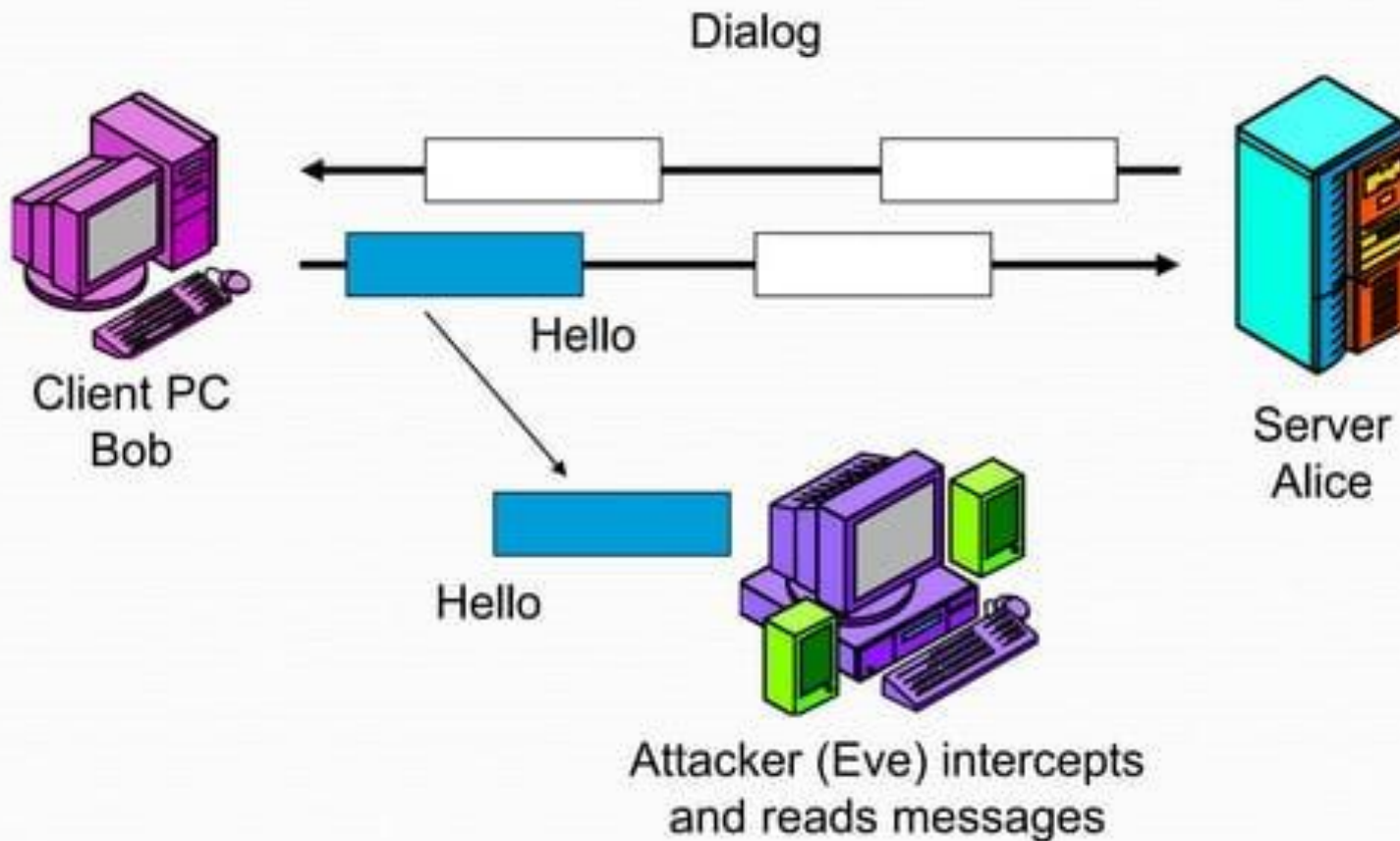
- Opponent finds out the contents or the actual messages being transmitted.

Passive Attacks



(a) Release of message contents

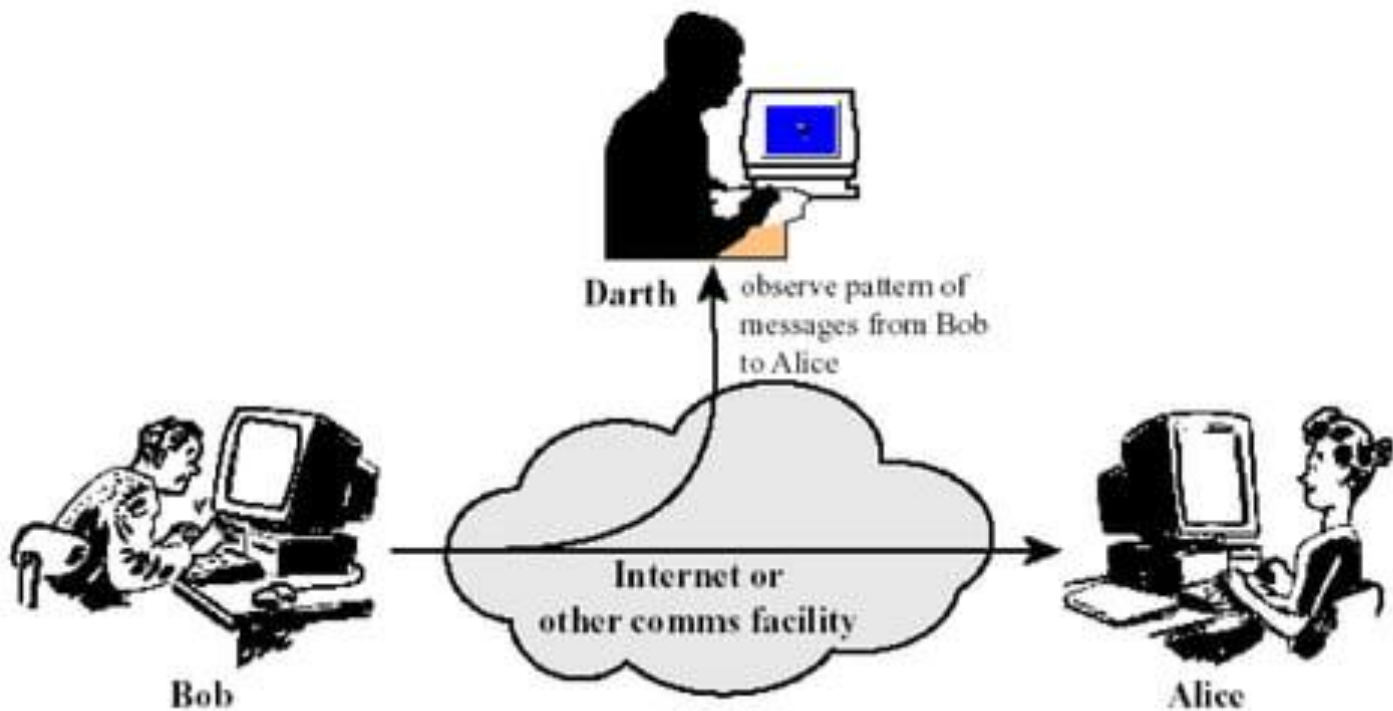
Eavesdropping on a Dialog



Traffic Analysis

- More subtle than release-of-message contents.
- The opponent figures out information being carried by the messages based on the frequency and timings of the message.

Passive Attacks



(b) Traffic analysis

Passive Attacks Problems

- Difficult to detect because there is no modification of data.
- Protection approach should be based on prevention rather than detection.

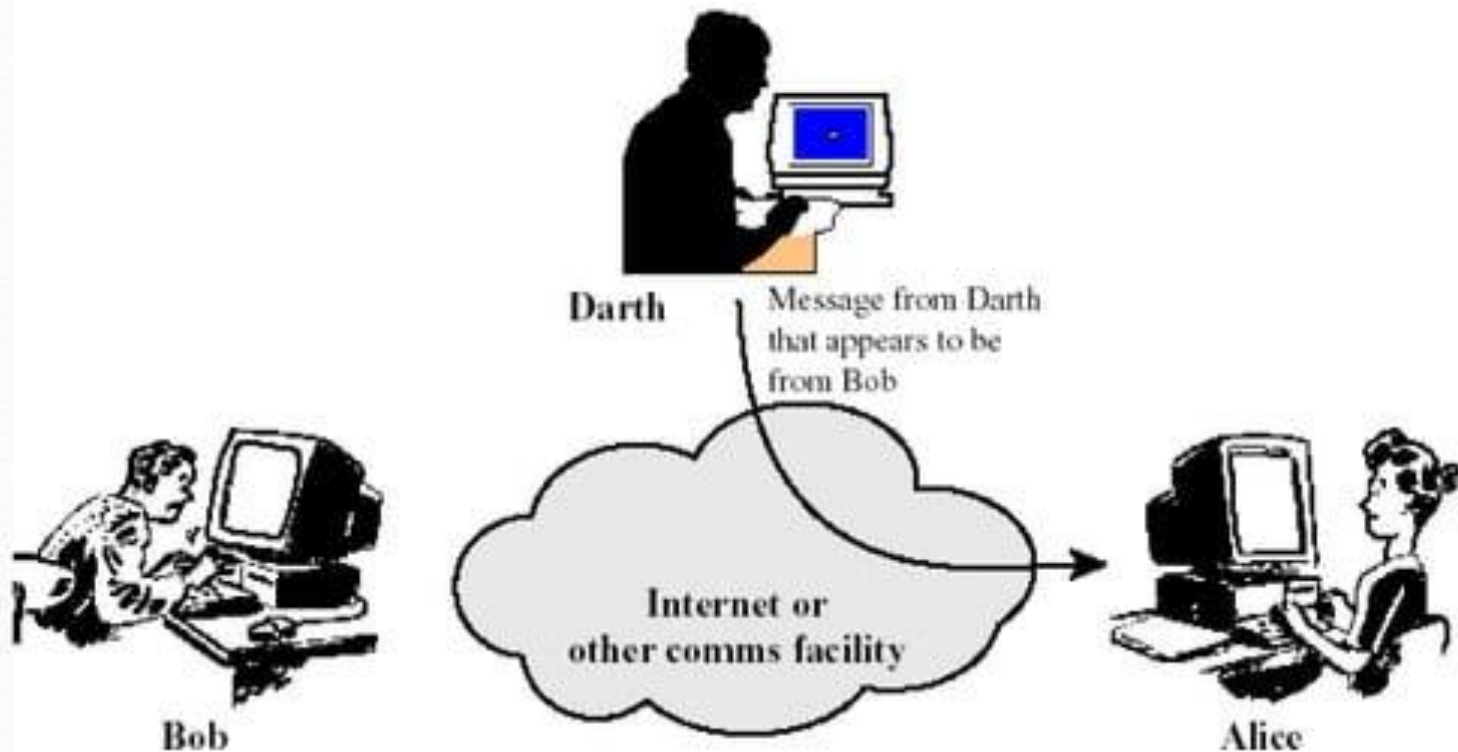
Active Attacks

- Active attacks involve some sort of modification of the data stream or the creation of a false stream.
- Four sub-categories:
 - Masquerade
 - Replay
 - Modification of Messages
 - Denial of service

Masquerade

- An entity pretends to be another.
- For the purpose of doing some other form of attack.
- Example a system claims its IP address to be what it is not, IP spoofing.

Active Attacks

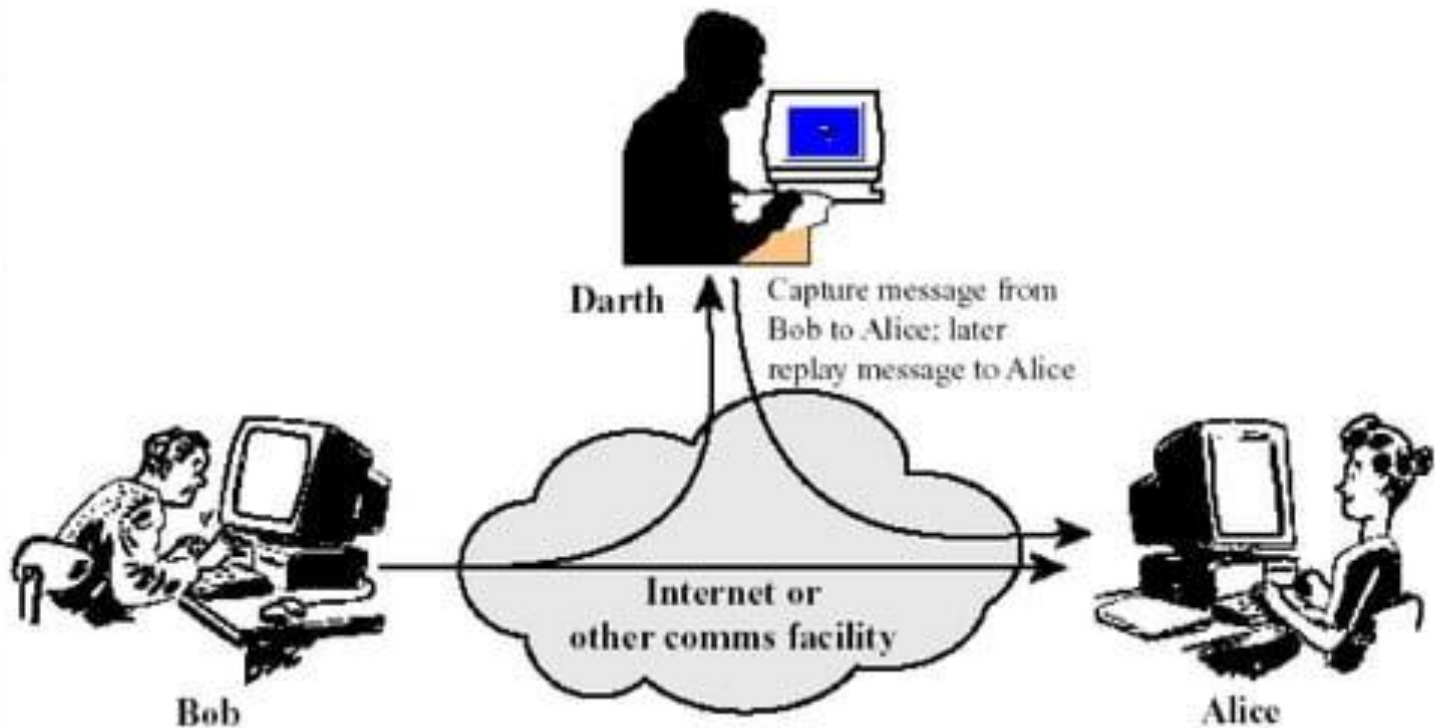


(a) Masquerade

Replay

- First passive capture of data and then its retransmission to produce an unauthorized effect.
- Could be disastrous in case of critical messages such as authentication sequences, even if the password were encrypted.

Active Attacks



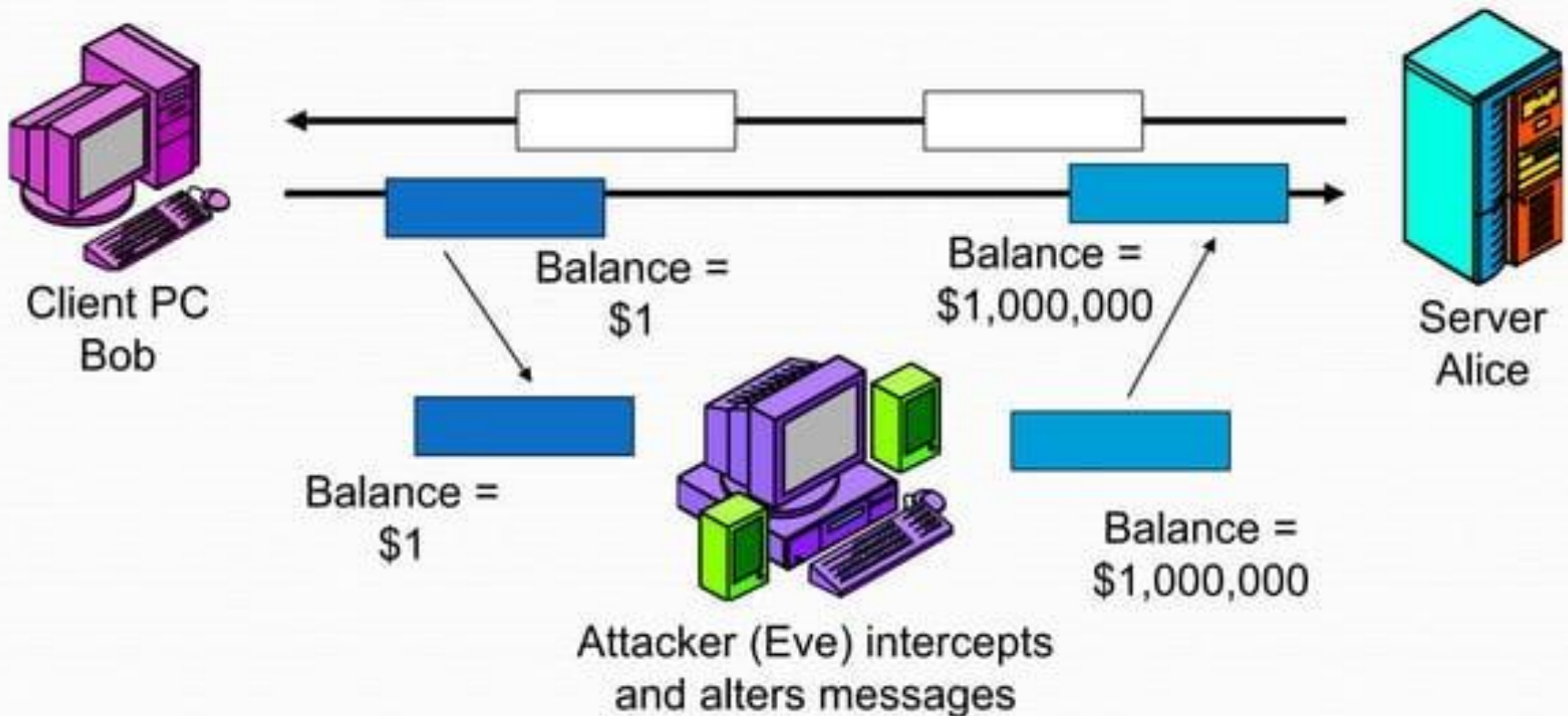
(b) Replay

Modification of Messages

- Some portion of a legitimate message is altered or messages are delayed or reordered to produce an unauthorized effect.

Message Alteration

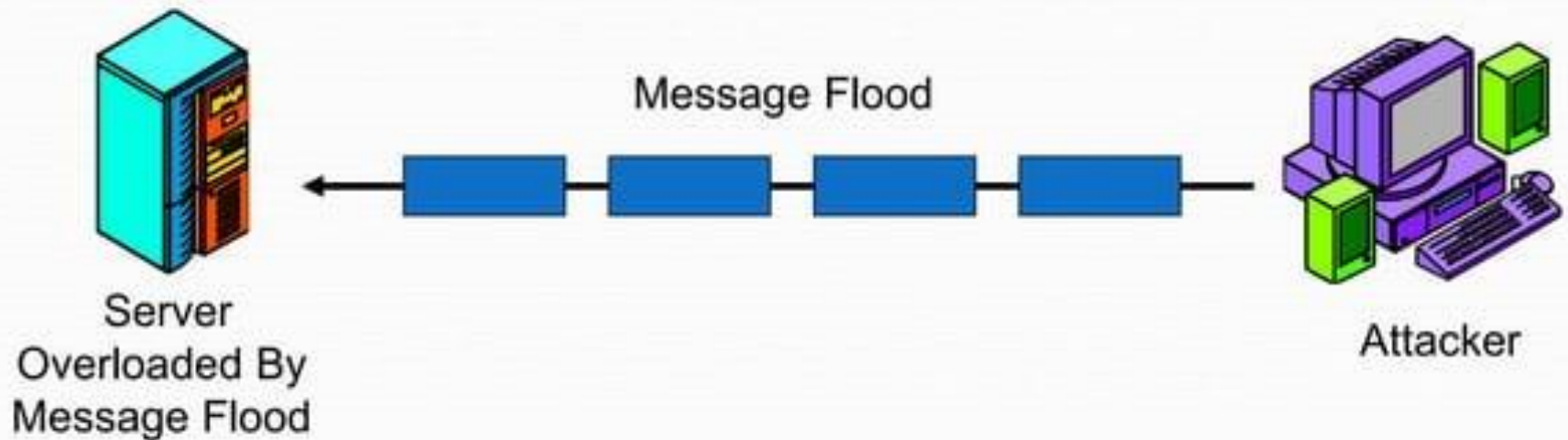
Dialog



Denial of Service - DOS

- Prevents the normal use or management of communication facilities.
- Such attacks have become very common on the Internet especially against web servers.

Denial-of-Service (DoS) Flooding Attack



In a denial-of-service attack, a hacker compromises a system and uses that system to attack the target computer, flooding it with more requests for services than the target can handle.

In a distributed denial-of-service attack, dozens or even hundreds of computers (known as zombies) are compromised, loaded with DoS attack software and then remotely activated by the hacker to conduct a coordinated attack.

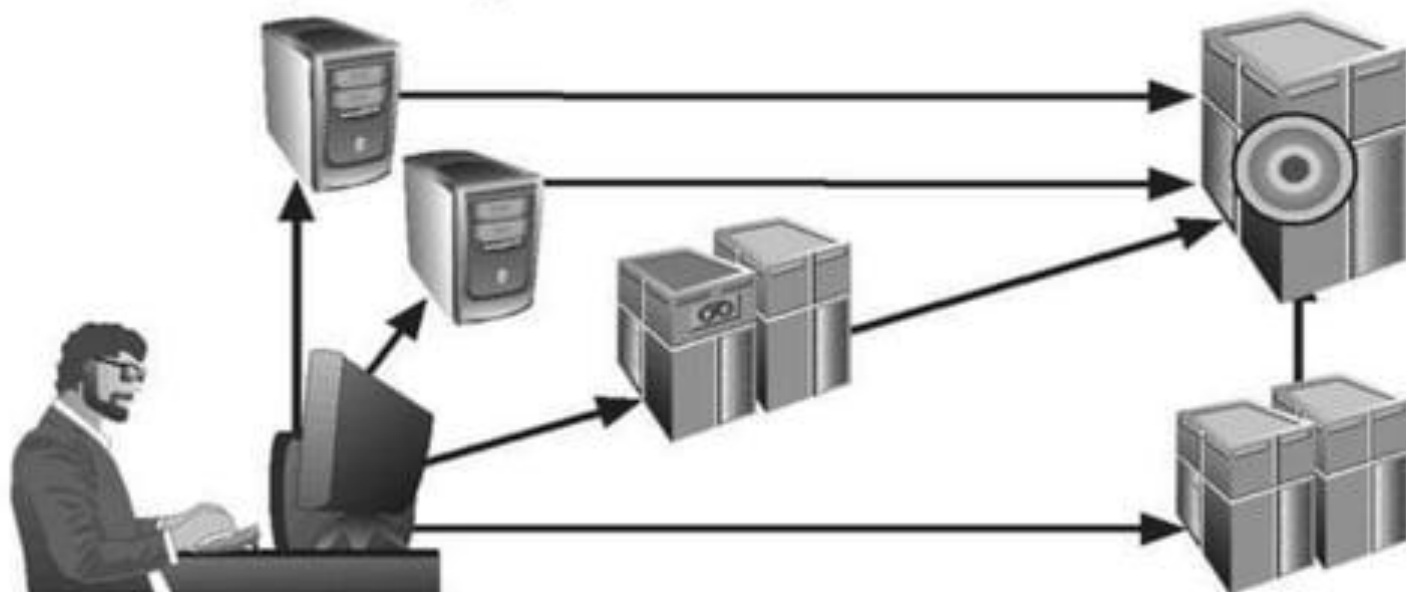


FIGURE 2-9 Denial-of-Service Attacks